

Replacing VPN: A Technical Look at Remote Access with ~~SASE~~ ZTNA

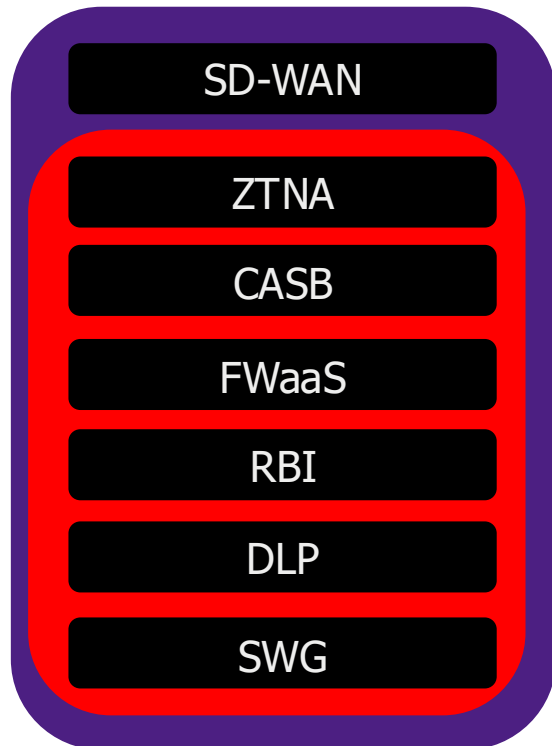
Marius Sandbu
Sopra Steria | Cloud Evangelist
Marius.sandbu@soprasteria.com



virtual expo

Marketing Bingo!

Some of the vendors in this ecosystem....



Microsoft
Citrix
Omnissa

Fortinet
Palo Alto
Checkpoint

Cloudflare
Netscope
ZScaler



Some a bit more ambitious than others...

So why replace VPN?

To name a few.....

VPN Client Vulnerability: Cisco AnyConnect Security Mobility Client
(Manual Workaround Needed... No Patch Available)

CYBERSECURITY ADVISORY

Threat Actors Exploit Multiple Vulnerabilities in
Ivanti Connect Secure and Policy Secure Gateways

CYBERSECURITY ADVISORY

#StopRansomware: LockBit 3.0 Ransomware
Affiliates Exploit CVE 2023-4966 Citrix Bleed
Vulnerability

Release D

CISA says critical Fortinet RCE flaw now exploited in attacks

By Sergiu Gatlan

October 9, 2024 06:07 PM 0

**Advisory: Active
Exploitation of
SonicWall VPNs**



sopra  steria

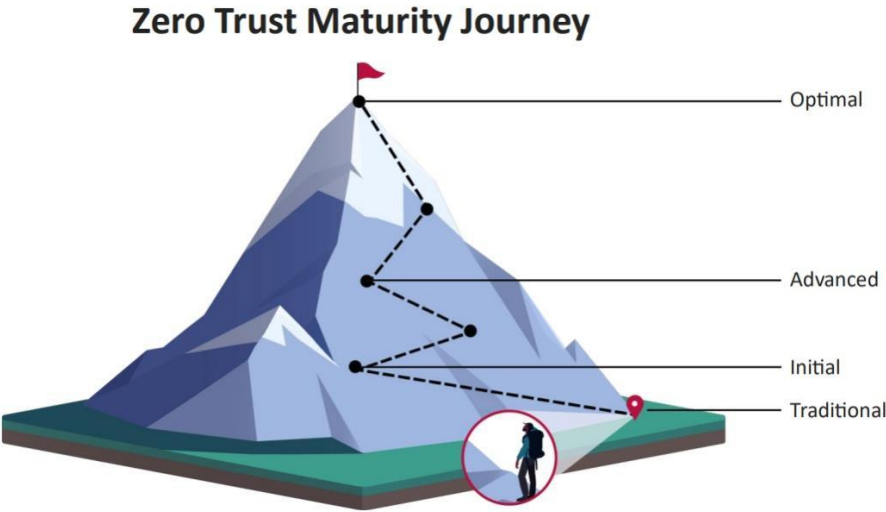
What are the different components in SASE?

- **Adopting the Zero-Trust design principals**
- **The components**
 - Zero-Trust Network Access (ZTNA)
 - Secure Web Gateway (SWG)
 - Cloud Access Security Broker (CASB)
 - Firewall-as-a-Service (FWaaS)
 - Remote Browser Isolation (RBI)
 - Data loss prevention (DLP)
 - SD-WAN
 - **+ Depending on which vendor you ask**



**Regular Internet
Highway**

Which Zero-Trust design principals?



Zero Trust Maturity Model Version 2.0

Mature level - Optimal

Identity	Devices	Networks	Workloads	Data
Continuous evaluation	Resource Access based on device posture	Distributed micro-perimeter	Continuously authorizes application access	Implements data loss prevention that dynamically blocks suspected data exfiltration.
Phishing resistant MFA	Compliance with threat detection	Visibility into all network traffic	Advanced threat protections added into all application workflows	Automates data categorization and labeling
Session based access	Vulnerability Management	Networks are defined using infrastructure-as-code	Makes all applications available over open public networks to authorized devices and users	Encrypts data in use where appropriate.

SD-WAN

- **Optimize Internet traffic**
 - Path Selection – Select path with lowest latency & jitter
 - Application Awareness – Per application routing
 - WAN Optimization & TCP Optimization
 - QoS and traffic shaping (Multipath)
 - Most common deployment hybrid = **(Endpoint + middle mile)**

From Norway to different locations

Location	MPLS	Internet	Azure VWAN
Japan	208 MS	292 MS	222 MS
Australia	313 MS	367 MS	310 MS
USA	108 MS	134 MS	112 MS

CASB (Cloud Access Security Broker)

- **API-based integrations with SaaS services**

- Out-of-band (API access)
- Or Inline (integrated with SWG)

- **Many can ingest firewall and proxy logs**

- Microsoft ingests data from MDE
- Detects suspicious traffic and usage patterns
- Enforces security controls in real time based on analysis
- SaaS App discovery based upon traffic
- **Can be used to block access to SaaS services**
 - Either via agent policy or SWG policy

Cloud Discovery

Updated on Mar 26, 2026, 11:12 PM

Dashboard Discovered apps Discovered resources IP addresses Users Devices

Apps	IP addresses	Users	Devices	Traffic
21	1	3	1	5.5 GB ↑ 6 MB ↓ 5.5 GB

App categories < 1-5 of 15 > Tr

Customer support

IT services 1.3 GB

Collaboration 663 MB

Cloud computing platform 612 MB

Online meetings 31 MB

Sanctioned Unsanctioned Other

**Example with Microsoft
Defender for Cloud Apps**

Secure Web Gateway

- **...A Internet based forward proxy**
 - TLS Inspection & URL filtering
 - Scan for malicious and malware payloads
 - Traffic logging
 - Inline DLP (Often integrated or custom)
 - HTTP/TCP/DNS policies
 - Functionality varies based upon vendor

Allow Secure Web Gateway to proxy traffic



Forward traffic to Cloudflare to filter outbound traffic and traffic directed to resources connected via your Cloudflare or WAN tunnels. You can choose which protocols to forward, but we recommend proxying all traffic for the best security.

Select protocols to forward

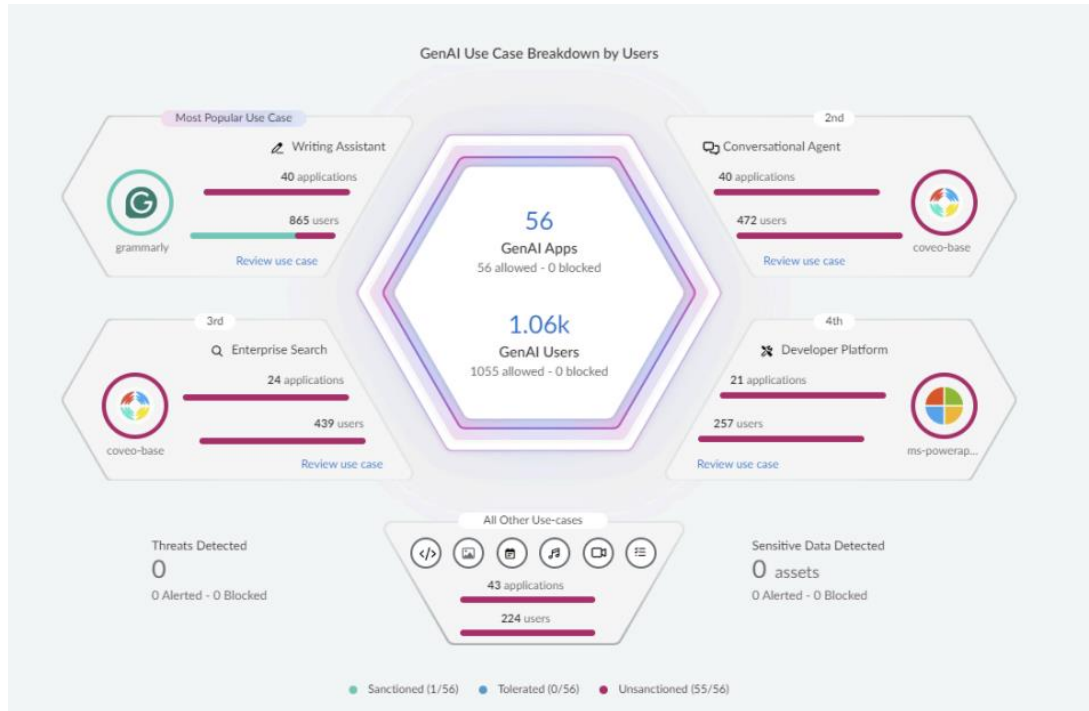
☒ TCP (required)

☒ UDP (recommended)

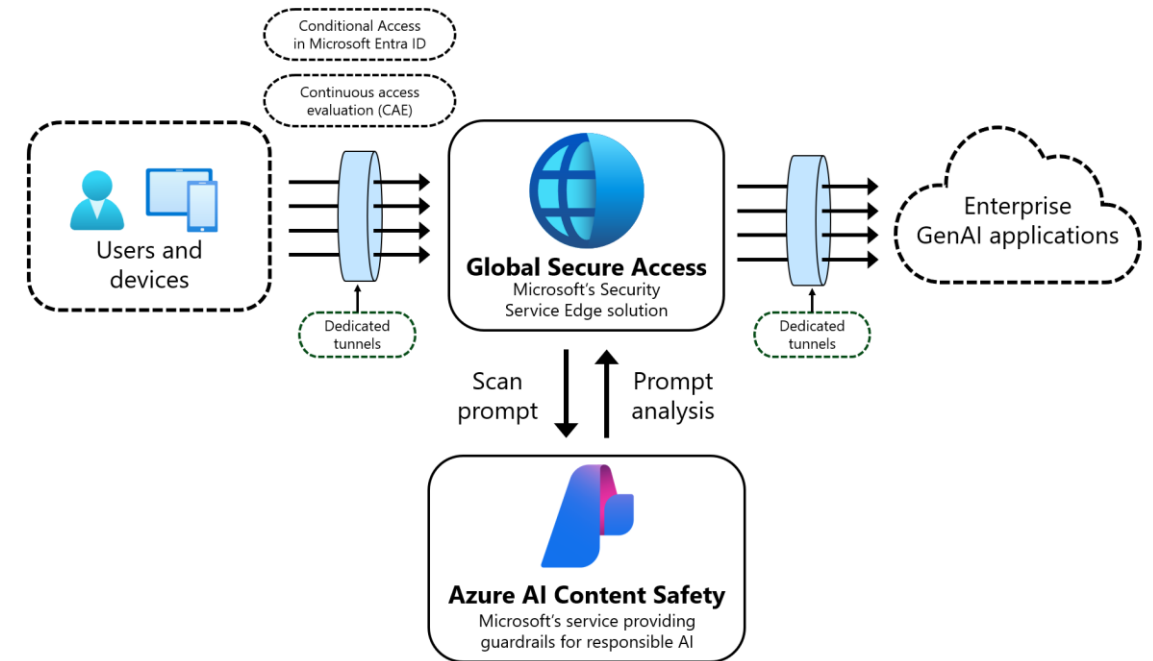
☐ ICMP (recommended)

Beta

Features with more focus on protecting AI



Prisma AI Dashboard

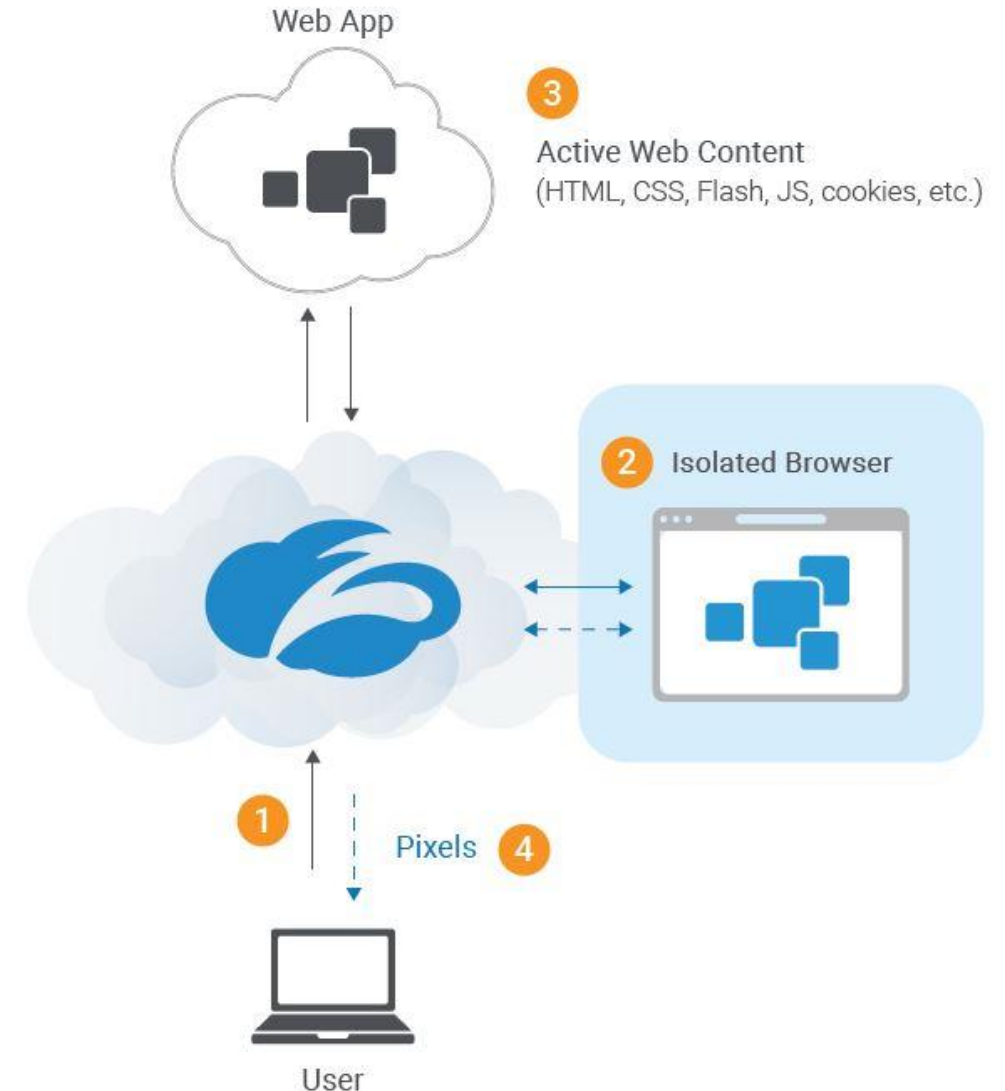


Block GenAI usage

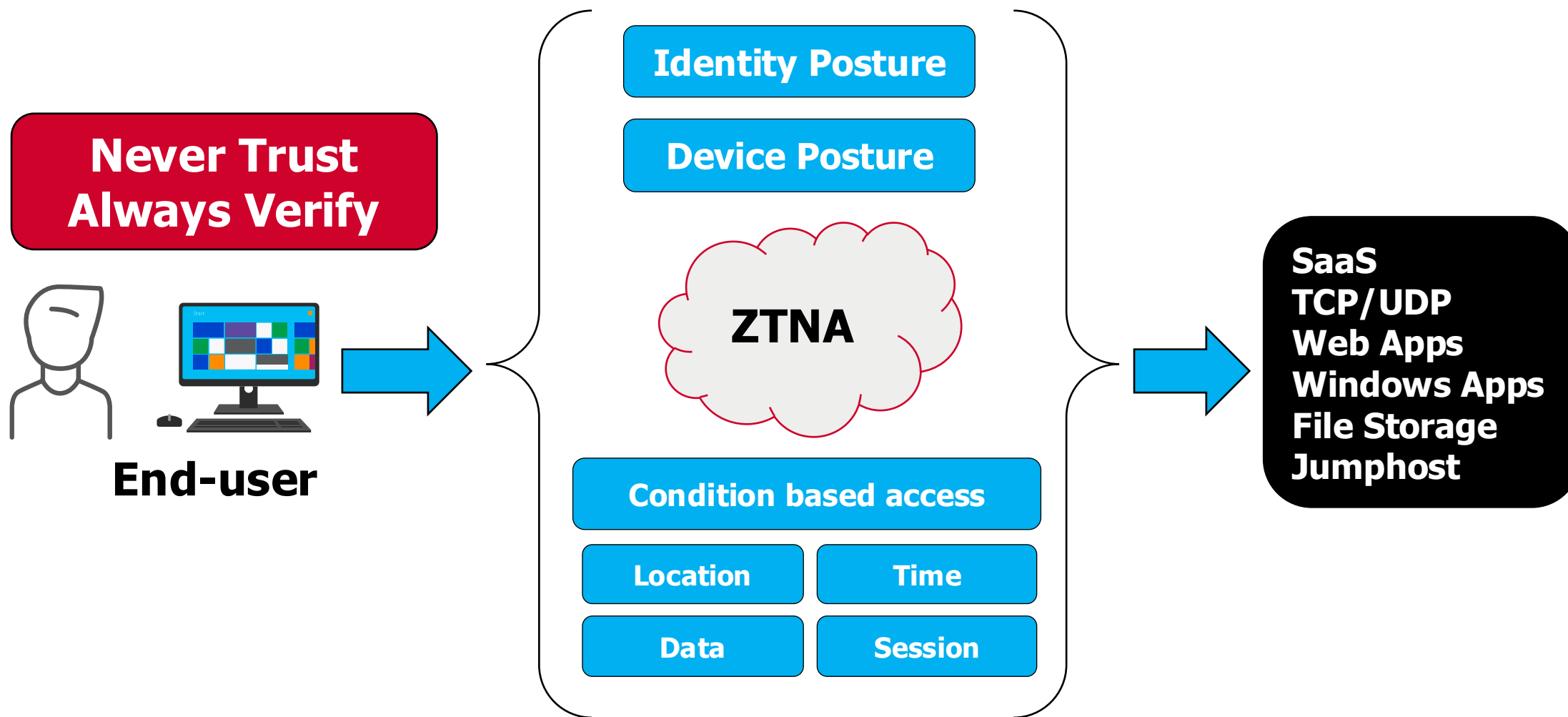
- **Secure Web Gateway / CASB**
 - **Remote Browser**
- **Integration with DLP policies**

Remote Browser Isolation

- **Provides cloud based browser for processing**
 - Some have option for on-premises deployment
 - Chromium sandbox with streamed content from the SWG
- **Either with custom browser or extend existing**
- **Combined with SWG for policy control**
- **Citrix and Omnisca also have custom integrations**
 - Omnisca and Microsoft Edge connector
 - Citrix and Chrome Enterprise
 - Provide posture check for unmanaged device



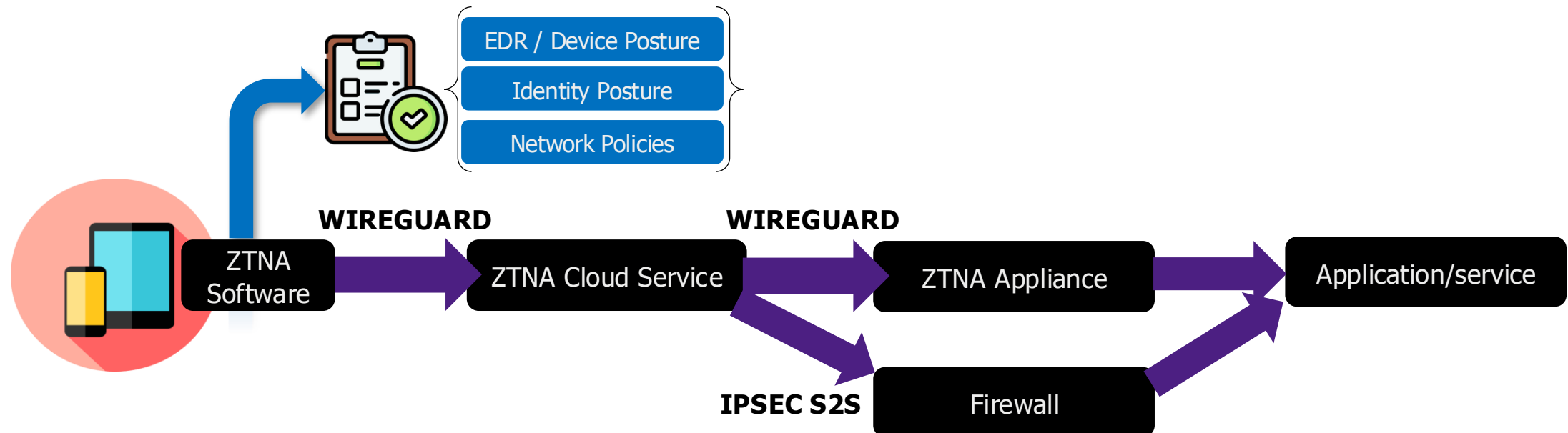
Zero-Trust Network Access



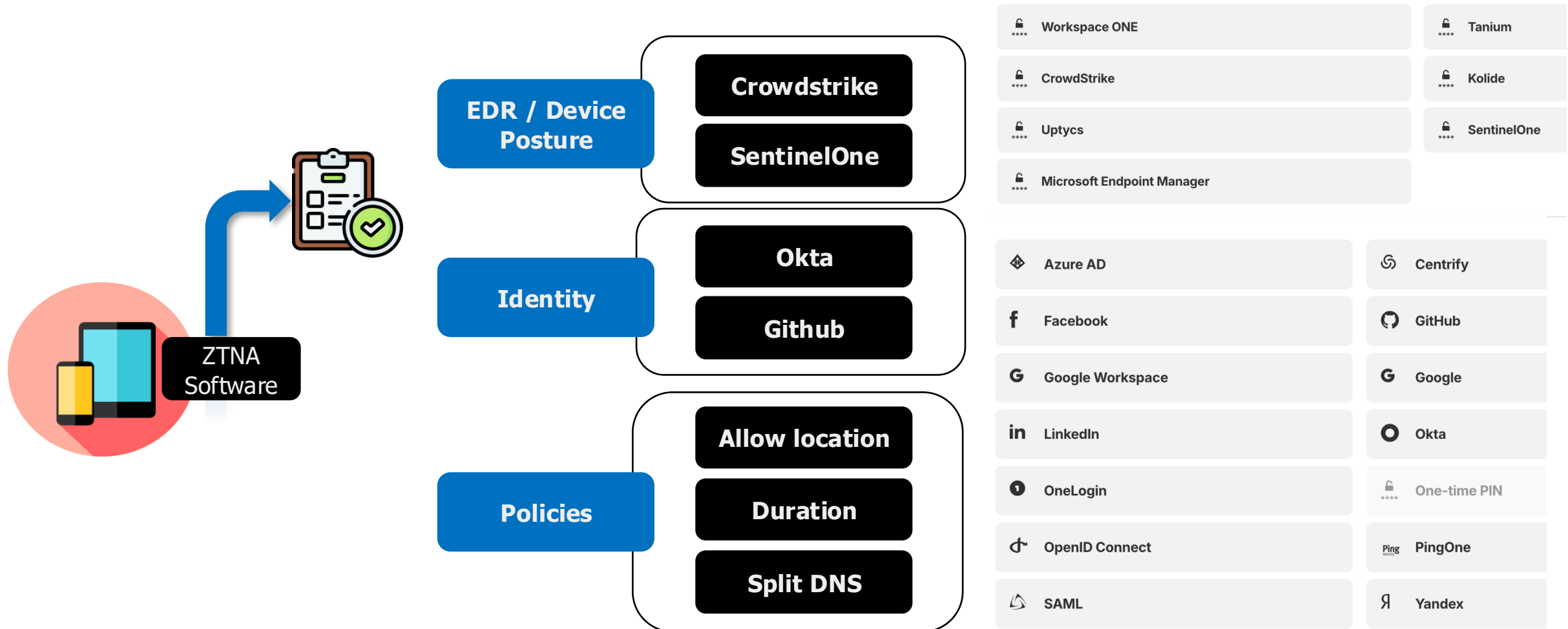
ZTNA – Overview traffic flow

- Client installed on the endpoint (Adds a NIC filter driver to the OS)
- Connects to a ZTNA Cloud service (or directly to an internet facing appliance)
- Globally distributed Cloud service (**Connects to the closest PoP**)
- ZTNA Cloud Service routes traffic to an **appliance or S2S VPN**
- Policies configured defines which traffic gets routed
- **Different protocols that are used depending on vendor** (gRPC, MASQUE, WIREGUARD, QUIC)

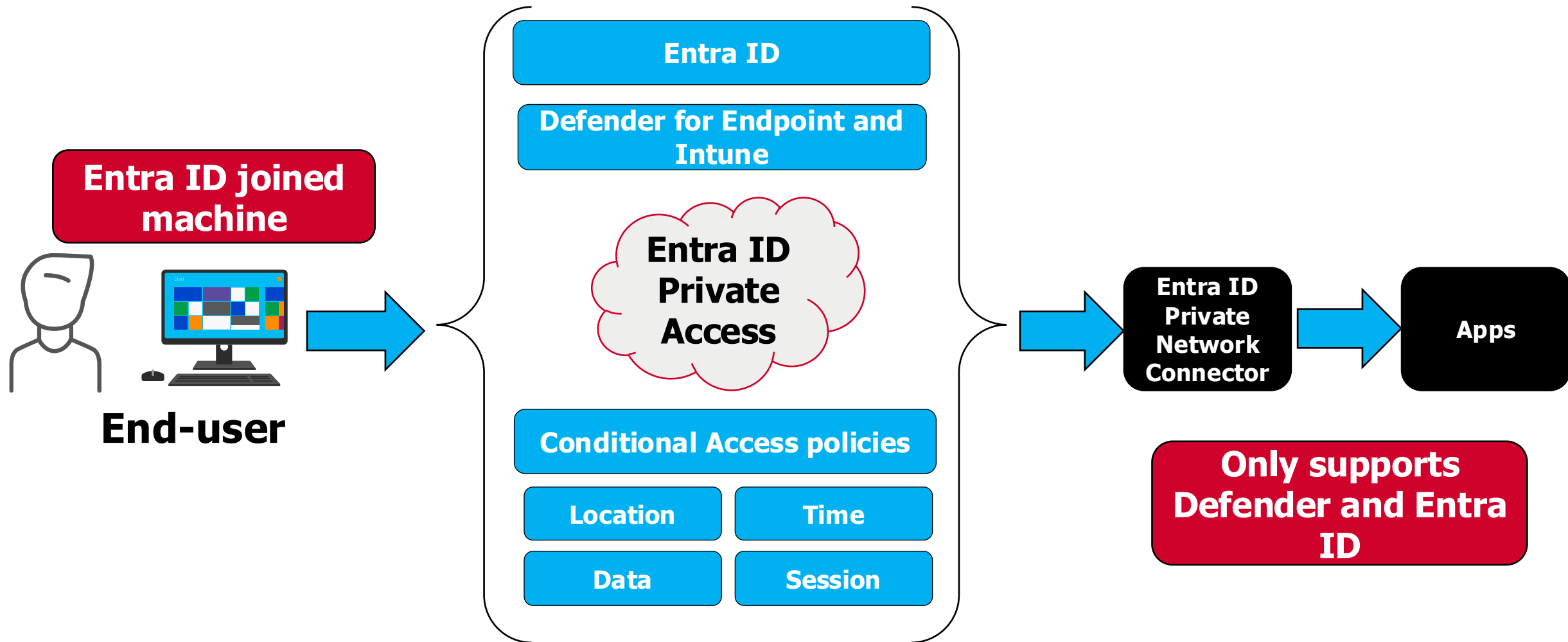
**Does not expose
service directly to
Internet**



ZTNA – Integrations (Can be a wide range)



Example with Entra ID Private Access

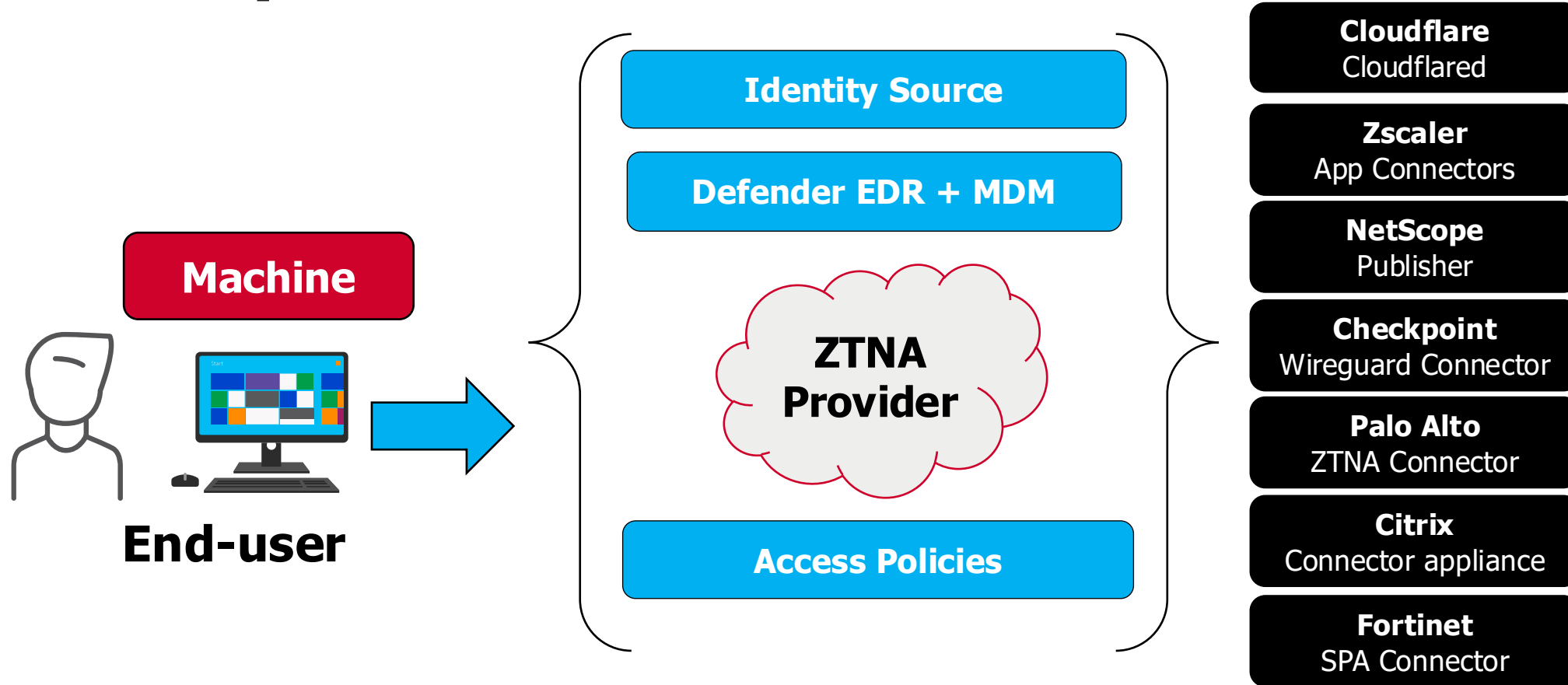


Some limitations with Private Access

- **Does not** fully support IPv6
- **Does not support** DoH (DNS-Over-HTTPS)
- **Does not support** QUIC for internet services (only for Private and M365)
- **Can support Entra ID B2B** If device is home to the main Entra ID Tenant
- **Single label domains are not supported** - For instance <https://service01>
- **Tunneling traffic by IP Address** requires that the IP Ranges are outside of the end-user device local subnet (192.168.0.0/24) to 192.168.0.0/24)
- **Support AVD** (Not multi-session)
- **Remember that Apple devices do not support routing traffic with services that end with .local**
- For Android requires Defender for Endpoint installed...

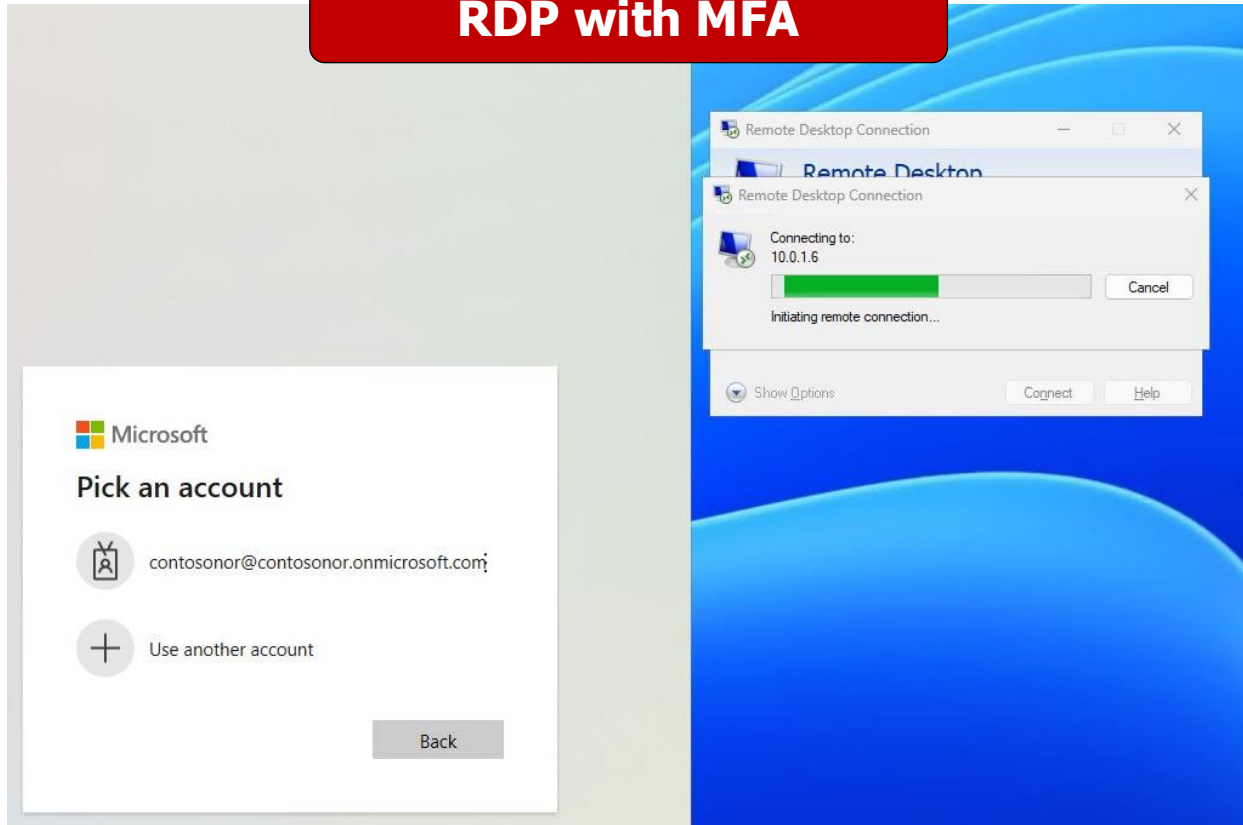
Some of these limits also apply to other vendors...

Example with all the others...

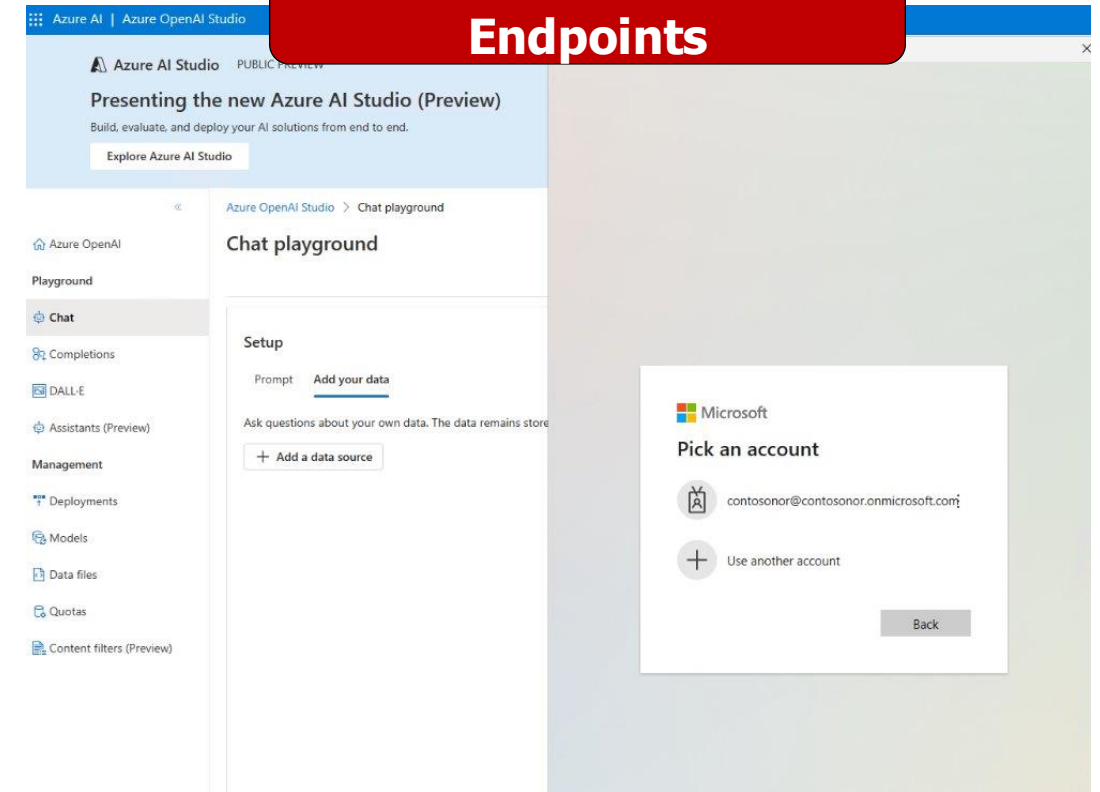


Some nifty scenarios

RDP with MFA



Services with Private Endpoints



<https://msandbu.org/ztna-for-azure-private-endpoint-using-entra-private-access/>

Demo with Cloudflare tunnel

Some important considerations

- **What are "must-solve" use-cases**
 - Minimize security risk from exposed VPN infrastructure?
 - Gain better visibility into user and application traffic ?
 - Replace implicit trust with verified, least-privilege access?
- **What does our environment look like?**
 - Existing ecosystem: EDR, Identity (Entra ID/Okta), device management (Intune/JAMF), applications and services
 - Where do users work — primarily office, hybrid, or fully remote?
 - What percentage of traffic is SaaS vs. private applications vs. internet?
 - Do we have branch offices that need site-to-site connectivity?

Vendor ecosystem

Feature	Microsoft	Cloudflare SASE	Citrix (ZTNA)
ZTNA Service	Global Secure Access – Private Access	Cloudflare Zero-Trust	Citrix Secure Private Access
Deployment type	Cloud Service + Appliance	Cloud Service + Appliance	Hybrid (Cloud or direct data path)
Appliance	Windows Server	Service (Linux/Windows) or container	Appliance
TLS inspection	Yes	Yes	No
Identity Service support	Entra ID	SAML / OpenID / Service Account	SAML / OpenID /
Device Posture support	Intune / Defender	Crowdstrike, Workspace One, Tanium, Sentinel One, Defender	Custom, Intune, Crowdstrike and Jamf
OS Support	Windows / Mac / Android / iOS	Windows / Mac / Android / iOS / Linux	Windows / Mac / iOS / Linux
Secure Web Gateway	Yes	Yes	No
Remote Browser Isolation	No	Yes	Yes
Protocol	gRPC	MASQUE/Wireguard	QUIC

Vendor ecosystem

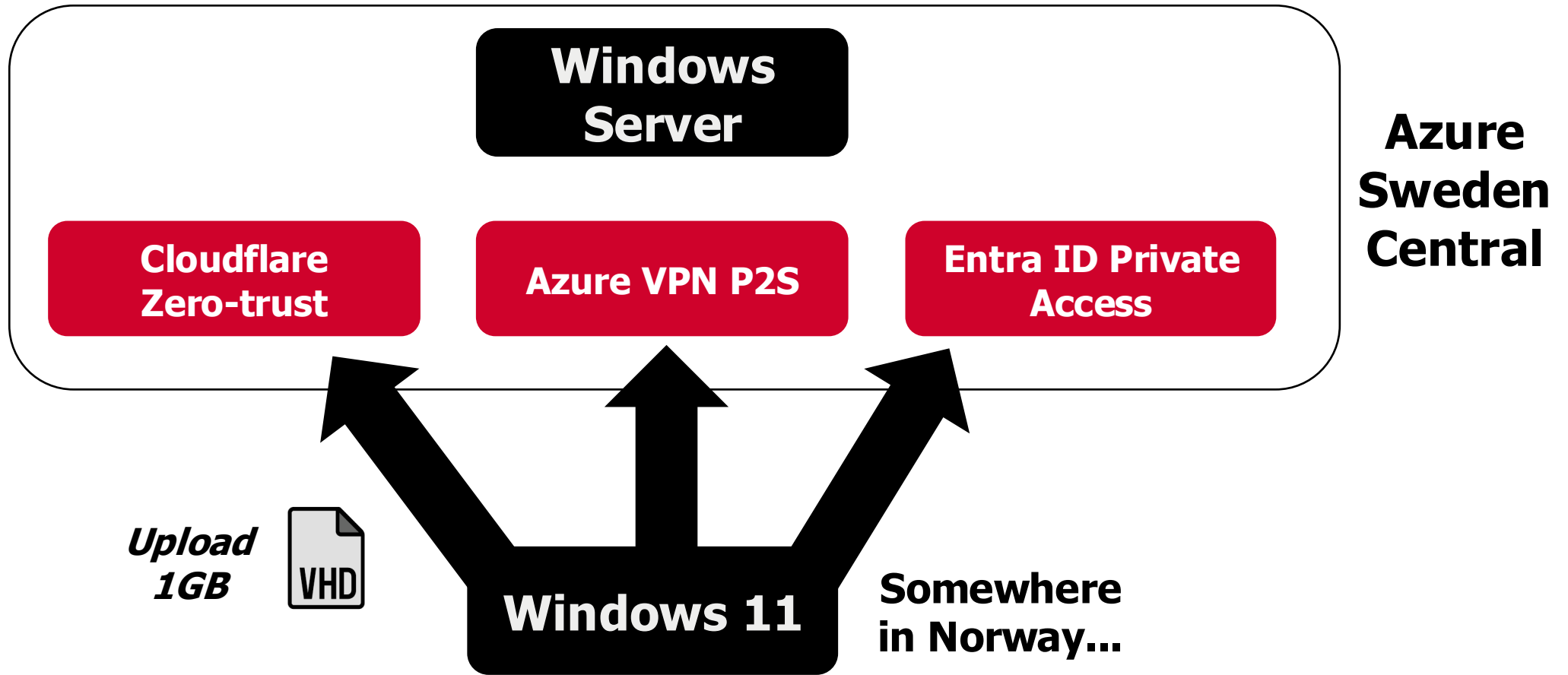
Feature	Checkpoint	Palo Alto	ZScaler
ZTNA Service	Checkpoint Harmony	Prisma Access	ZScaler Private Access (ZPA)
Deployment type	VM or IPSEC tunnel	Appliance or IPSEC tunnel (service Connections)	Appliance or Docker Container
Appliance	Linux VM	Linux VM	Linux VM or Container
TLS inspection	Yes	Yes	Yes
Identity Service support	SAML, Machine accounts and AD	SAML, Machine accounts and SCIM, AD	SAML, Machine accounts and SCIM, AD
Device Posture support	Custom Policy Engine	Custom Policy Engine	Microsoft Defender, Sentinelone, Crowdstrike, Carbon Black, Custom, Jamf
OS Support	Windows / Mac / Android / iOS / Linux	Windows / Mac / Android / iOS / Linux	Windows / Mac / Android / iOS / Linux
Secure Web Gateway	Yes	Yes	Yes
Remote Browser Isolation	Yes	Yes	Yes
Protocol	Wireguard	IPSEC	Have no clue...

Vendor ecosystem and features

Other somewhat important features

- Double Encryption (Regulated Sectors)
- Branch-to-Branch – Endpoint-to-endpoint
- Dedicated IP with Packet flow traceability
- Reuse of NGFW access for IPSEC
- Colocation Connect feature
- SIEM & DLP integration (example Sentinel & Purview)
- Automation capabilities (Infrastructure as Code)
- Global Capacity (and features!)
- Routable L3 Network
- Compliance requirements
- IP overlapping from client networks
- Sandboxing & malware detection
- **SUPPORT!!**

Performance is still important



Performance difference some examples

- **Cloudflare w/MASQUE first attempt (~3-4MB/s) wrong PoP**
- Cloudflare w/MASQUE (~35MB/s) UDP
- Cloudflare w/Wireguard - FIPS (~27MB/s) UDP
- P2S VPN Azure (~38MB/s) UDP
- Entra ID Private Access (~22MB/s) TCP
- **PoP location is IMPORTANT**

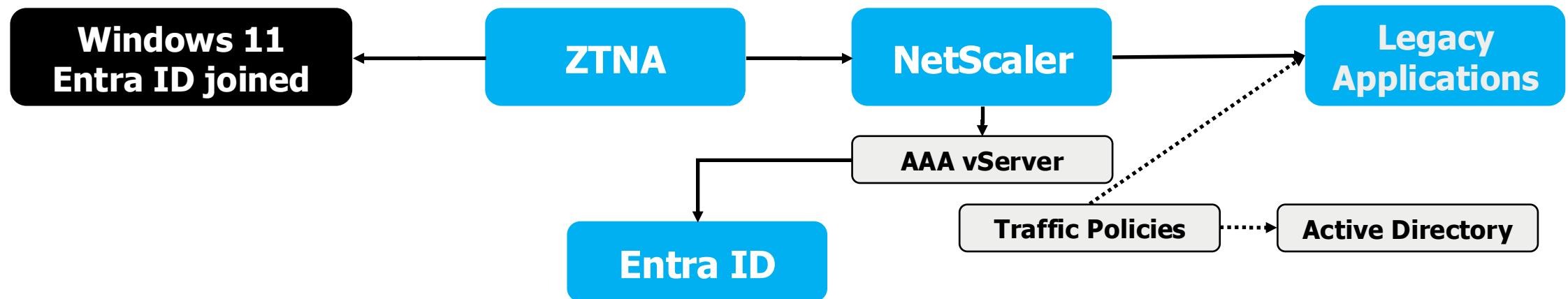
Other things that can impact performance
MTU Size, TCP Anycast and
DNS Geo lookup

How Deutsche Telekom Makes Cloudflare Re-Route Traffic Around the Globe

February 24, 2025 - 4 min read

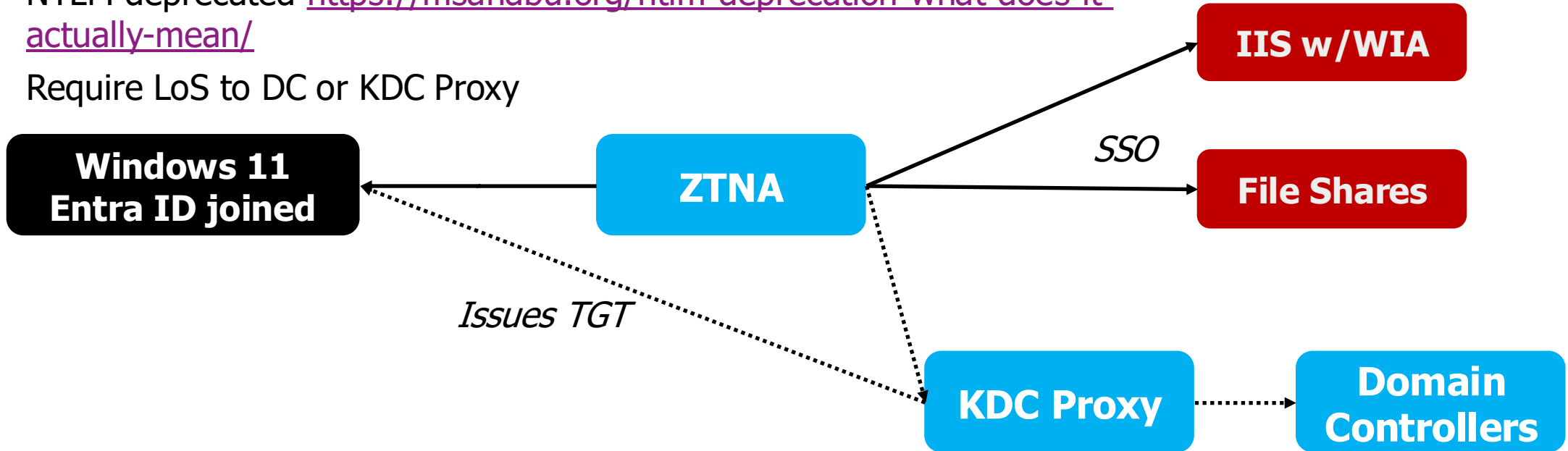
Handling legacy applications

- Endpoints moving to Entra ID Joined (Supports Entra ID based services)
- Not all services support Entra ID
- Forms / Kerberos (KDC) / NTLM / HTTP
- Need something to handle protocol translation
- Convert from OIDC/SAML to KCD to Active Directory
- Many ADCs that can handle protocol translation (even Azure Application Proxy - KDC)



What does Microsoft provide?

- Cloud Kerberos Trust - Requires WHfB and Entra ID Sync
- Provides SSO for Kerberos and NTLM based services
- NTLM deprecated <https://msandbu.org/ntlm-deprecation-what-does-it-actually-mean/>
- Require LoS to DC or KDC Proxy



KDC Configuration:

<https://cloudbrothers.info/windows-business-cloud-trust-kdc-proxy>

What does SASE not aim at solving?

- EDR and device posture (CrowdStrike/Defender)
- Vulnerability management (Qualys, Tenable)
- Identity lifecycle management (iDP often outside)
- Does not solve east-west traffic inside the DC/Cloud (Microsegmentation)
- DLP should be integrated not a core part

Summary and some reading material

<https://sasecloudmap.com/#loc=3.66/51.93/14.88>

<https://sase.cloud/>

